

The Authorization Maturity Model

A CISO's Benchmark for 2026



Foreword. Why we wrote this.....

Chapter 1: The authorization blind spot.....

- Shift 1: Credentials still work, the damage happens after.....
- Shift 2: Human users are no longer the majority.....
- Shift 3: Regulators have made the CISO personally liable.....
- Shift 4: The EU AI Act made agent authorization a compliance issue.....

Chapter 2: The four stages of authorization maturity.....

- Stage 1. Ad-hoc.....
- Stage 2. Documented.....
- Stage 3. Centralized.....
- Stage 4. Governed.....

Chapter 3: Self-assessment. Where are you today?.....

Chapter 4: Risks and regulatory exposure at each stage.....

- Exposure at Stage 1.....
- Exposure at Stage 2.....
- Exposure at Stage 3.....
- Exposure at Stage 4.....

Chapter 5: Moving up the model.....

- Stage 1 to Stage 2.....
- Stage 2 to Stage 3.....
- Stage 3 to Stage 4.....

Chapter 6: What good looks like.....

- Outcome 1: Exposure duration.....
- Outcome 2: Time-to-revoke.....
- Outcome 3: Policy coverage.....
- Outcome 4: Decision log completeness.....
- Outcome 5: Post-event analysis cadence.....
- Outcome 6: Delegation reconstruction time.....

Chapter 7: Authorization for AI agents.....

- Why human-shaped authorization breaks for agents.....
- Per-hop authorization is the architectural floor.....
- Audit trail collapse is the compliance risk.....
- What CISOs should be asking vendors right now.....
- What changes in your maturity model.....

Chapter 8: A 30, 60, and 90 day plan.....

- The first thirty days are about establishing visibility.....
- Days thirty-one to sixty are about picking the layer.....
- Days sixty-one to ninety are about proving the approach and committing to the program.....
- Close the gap with Cerbos.....

About this guide.....

Foreword. Why we wrote this

Over the last year we have had hundreds of conversations with security leaders across regulated industries including fintech, healthcare, and government, as well as B2B SaaS. Different industries, different stacks, different regulators, and yet the same gap kept coming up in the same shape.

The authentication story is in good order. Identity providers are in place. IGA is managing the joiner-mover-leaver process. MFA is enforced across the workforce. Passwordless is being rolled out. Conditional access is on. The board has been told the login problem is solved, and on the evidence of the last five years of investment, it largely is.

Then the conversation turns to what happens after login, and the answers get quieter. Authorization logic lives inside each application's code. Different teams have done it differently. Nobody has a single view of who can access what, on what grounds, for how long, under what conditions. Audit evidence takes weeks to assemble and lives in screenshots. Former employees occasionally show up in logs. Service accounts run with permissions nobody has reviewed since the service was stood up. AI agents were added last quarter and nobody is entirely sure what they can reach.

The CISO is carrying personal liability for a layer of the stack they cannot see.

This guide is about that layer. It gives you a vocabulary for naming where your program sits today, a map of what auditors and attackers will find at each stage, and a path for moving the program forward at a pace the business can absorb. It is built from what security leaders have told us, from the published work of leading IAM and security analysts, from peer contributions to the Cloud Security Alliance's CISO Mythos draft, and from the regulatory weight coming out of NIS2, DORA, and the US SEC cyber governance rules.

You do not need to be a Cerbos customer for any of this to be useful. The self-assessment in Chapter 3 works with any authorization program. The checklist in the appendix does too. Read it, use what applies, come back to the parts that do not yet.

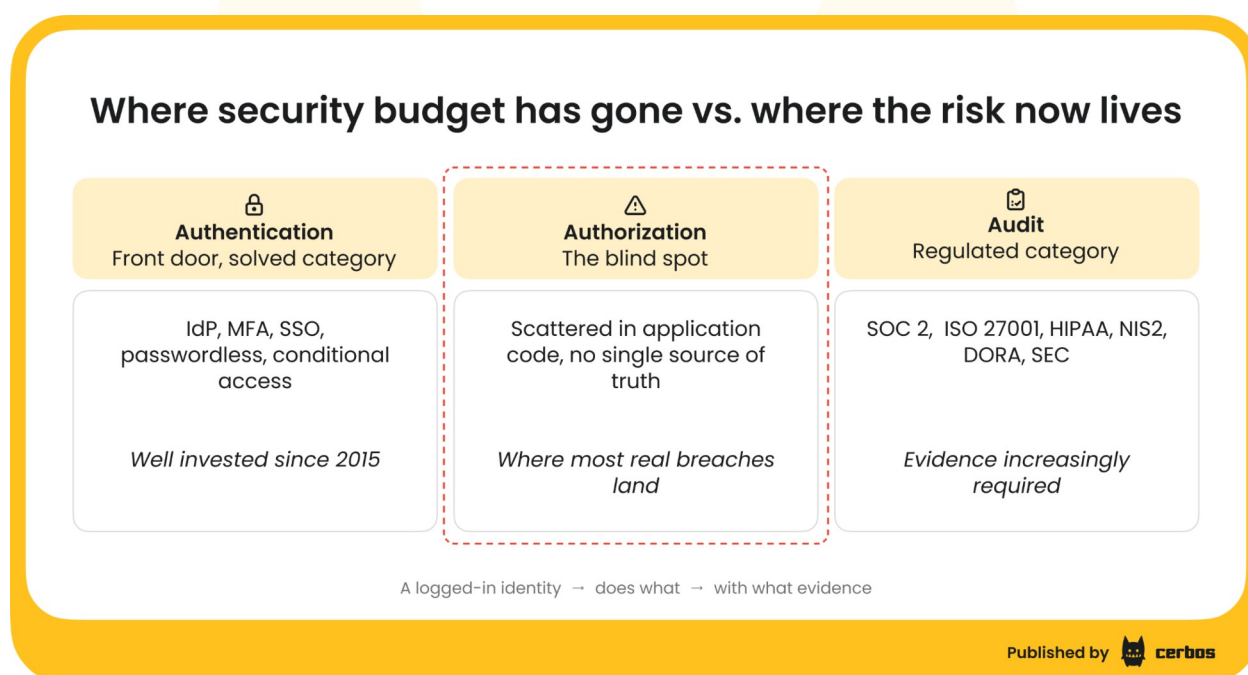
Chapter 1

The authorization blind spot



For the last fifteen years, most of the security budget has gone on the front door. Identity providers replaced LDAP, MFA layered on top of passwords, SSO replaced a sprawl of logins, and conditional access layered context on top of the whole thing. The results have been real. Phishing-resistant authentication is now the default in most serious organizations. The weakest link in a 2010-era breach, the password, is no longer the weakest link in a 2026-era breach.

The problem is that the front door is no longer where the risk lives.



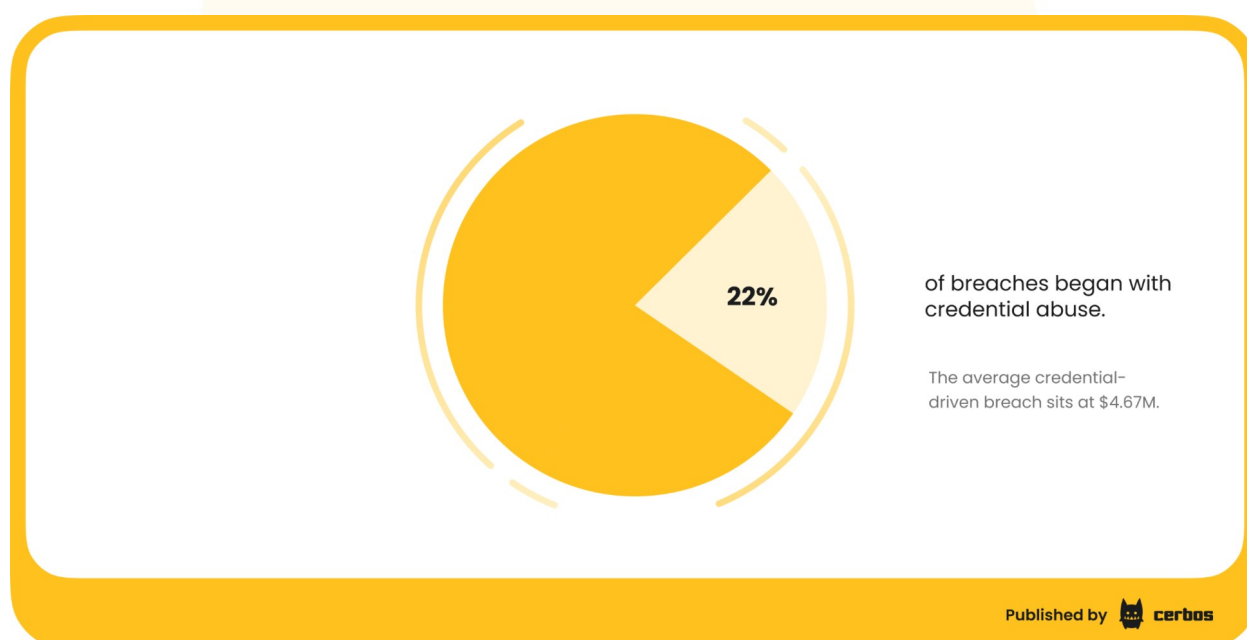
That gap is not an accident. The budget, and the industry's attention, stayed on the front door even as the risk moved behind it. Helen Patton, cybersecurity advisor at Cisco and former CISO at The Ohio State University, named the same shift. "Over the last decade, the scope of the cybersecurity function has become bigger and bigger, while the focus of the cybersecurity industry has shrunk to a singular focus, external attack detection and defense." The security function has grown to cover everything that happens after login. The industry, in large part, has kept selling the login.

Once a user, a service, or an agent is inside, what they can actually do is controlled by authorization logic that was never built to carry the weight it now carries. In a typical mid-market SaaS company, permission checks sit inside dozens of codebases, maintained by dozens of teams, with no consistent convention between

them. **The CISO owns the risk on paper. Engineering owns the code in practice. Neither has a single source of truth, and the gap between the two is where most of the damage now happens.**

Four shifts have pushed this from a 2030 problem to a 2026 one.

Shift 1: Credentials still work, the damage happens after



The first shift is that credentials are still the way in, and the cost of that access has gone up. Verizon's [2025 DBIR](#) found that 22% of breaches began with credential abuse, and that 88% of basic web application attacks involved stolen credentials. IBM's [2025 breach report](#) put the average breach at \$4.44 million globally and \$10.22 million in the United States. Credential-driven breaches sit slightly above that average, at \$4.67 million. Every one of those numbers is a story about an attacker who walked through the front door with a valid credential. From the authentication system's perspective, nothing went wrong. Everything that did go wrong happened afterwards, in the part of the stack that decides what a logged-in identity is allowed to do. That is the authorization layer.

Shift 2: Human users are no longer the majority

The second shift is that human identities are no longer the interesting part of the estate. Non-human identities, service accounts, workloads, CI runners, bots, and now AI agents, have quietly taken over. CyberArk's [2025 landscape report](#) estimates machine identities outnumber human identities by 82 to 1 in a typical enterprise. The majority of those identities sit outside the formal ownership of the IAM team, governed instead by whoever happened to provision them. AI agents are adding to this number weekly. Phil Venables, the former CISO of Google Cloud and Goldman Sachs and now a partner at Ballistic Ventures, cut to the [underlying question at RSAC 2026](#):

"AI security is a meaningless phrase. Even agentic security is a meaningless phrase. You drop it down a level and say, what does it mean to give identity to agents?"



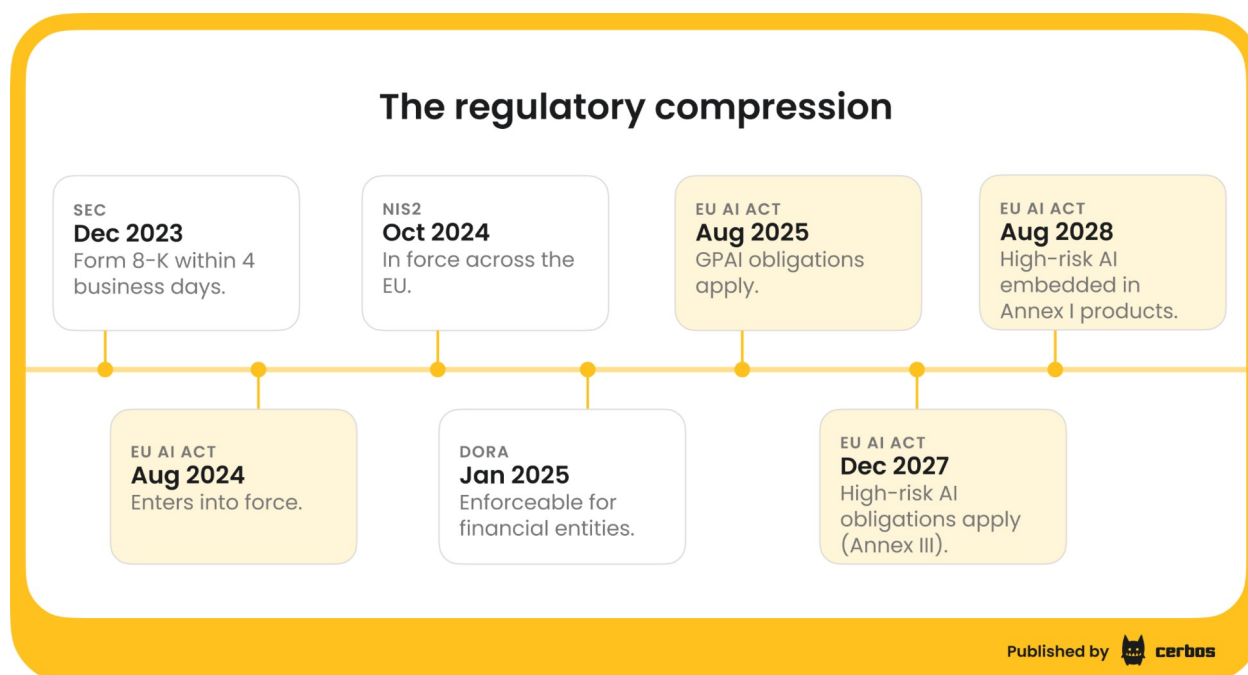
Phil Venables
Partner



Published by  **cerbos**

Andi Hindle, Identiverse chair, has recently framed the same point from the other side: "Human users are the edge case. We have been designing access infrastructure around the smallest part of the estate. Authorization that was built to ask 'which role does this human have' does not handle an estate that is overwhelmingly not human."

Shift 3: Regulators have made the CISO personally liable



The third shift is that the regulatory picture has moved the problem onto the CISO's desk personally. The EU's NIS2 directive has been in force across member states since October 2024 and is now being enforced in earnest. Under [Article 20 of the directive](#), management bodies are required to approve and oversee their organization's cybersecurity risk management measures, and they can be held liable for non-compliance under the supervisory and enforcement provisions in Article 32. DORA has been fully enforceable for financial entities since January 2025. The US SEC's cyber disclosure rules have been live since December 2023 and are producing enforcement actions quarterly.

As James Eason, risk and compliance specialist, [told CSO Online](#), "CISOs can be held personally liable for data breaches where it is deemed that they have responded inefficiently, or if it is evident that any cover up has taken place."

The common thread across all three regimes is that regulators now expect management to be able to answer specific questions about access control, and to answer them from evidence rather than from assurance. "We trust our engineers" is not a regulatory answer any more.

Shift 4: The EU AI Act made agent authorization a compliance issue

The fourth shift sits one layer further out. The EU AI Act, which entered into force on 1 August 2024, has been moving through its phased application calendar since. Obligations for general-purpose AI providers applied from 2 August 2025. The obligations that matter most for the CISO, Articles 9, 10, 12, and 13 of Regulation (EU) 2024/1689, were originally scheduled to apply to high-risk AI systems from 2 August 2026. As of the May 2026 omnibus agreement, those dates have moved to 2 December 2027 for standalone Annex III systems and 2 August 2028 for AI embedded in Annex I regulated products. The delay does not change the substance of the obligations; it changes the runway.

Article 9 requires a documented risk management system maintained across the system's lifecycle. Article 10 sets data governance requirements for training, validation, and operational data. Article 12 requires record-keeping that lets an operator reconstruct what the system did, with what inputs. Article 13 requires transparency and clear information to deployers about how the system works and its limitations.

Jonathan Care, lead analyst on agentic AI at KuppingerCole, recently shared that this is the compliance event most organizations are least prepared for. "Most organizations are in denial about agent usage," he said. "Shadow AI is happening across enterprises despite claims of 'no agents.'" The audit trail required by Article 12 is the chain of who delegated what to which agent under which policy, replayable on demand. At most organizations today, that chain breaks the moment an agent calls another service. The Act has moved the agent authorization conversation from a future architecture question to a current compliance question.

Underneath these four shifts sits a fifth argument, made most forcefully by Kara Sprague, CEO of HackerOne. In her [velocity essay](#), she points out that the median remediation time has grown, while exploit development time has collapsed into hours.

"Cyber risk is no longer about what you haven't found, it's about what you haven't fixed."



Kara Sprague
CEO
hackerone

Published by  cerbos

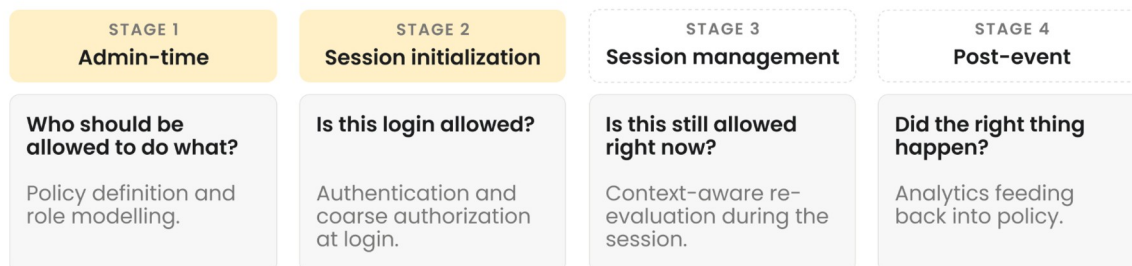
Her frame is vulnerability management, but the logic transfers directly. During a 200+ day remediation window, who still has access to the vulnerable service? How quickly can you revoke it when you need to? How would you prove you did? Those are authorization questions, and at most organizations they do not yet have clean answers.

The analyst community has been clear about where this is heading. In April 2026, KuppingerCole's Phillip Messerschmidt [argued](#) that "authorization is no longer a single decision, but an ongoing process." He separates authorization into four timing stages, the administrative-time definition of who should be allowed to do what, the session initialization check at login, the ongoing session management evaluation while work is being done, and the post-event analysis that feeds back into policy. Most programs today only cover the first two. "That," he writes, "leaves the familiar trade off between effort and risk."

This is the authorization blind spot. It sits between authentication and audit. It is where most real breaches now land, where most regulators are now looking, and where most security programs have the least visibility. The rest of this guide is an attempt to make it visible, one stage at a time.

Messerschmidt's four timing stages

Most programs only cover the first two. That is the gap.



Published by  **cerbos**

Chapter 2

The four stages of authorization maturity



Authorization programs do not sit on a single line. They cover different timing stages of a decision, they sit with different owners, they produce very different evidence for auditors, and they hand boards very different kinds of answers. Calling everything below Stage 4 "immature" is not the point. Most of the serious organizations we talk to sit at Stage 2 with a foot in Stage 3, and the useful work is naming that honestly rather than defending a spreadsheet.

The four stages on the next page each describe how authorization runs in practice, not how it is documented. They map directly onto Messerschmidt's four stages, so the language lines up with analyst framing and with the vocabulary your audit committee is starting to hear from its own advisors.

The four stages of authorization maturity

Each stage describes how authorization actually runs, not how it is documented.

STAGE 1 Ad-hoc	STAGE 2 Documented	STAGE 3 Centralized	STAGE 4 Governed
TIMING COVERED Admin-time only.	TIMING COVERED Admin-time + session initiation.	TIMING COVERED + session management.	TIMING COVERED + post-event analytics.
OWNERSHIP Scattered across engineering teams.	OWNERSHIP IAM for policy, engineering for enforcement.	OWNERSHIP Platform or security engineering, CISO visibility.	OWNERSHIP Security, with formal governance + board reporting.
AUDIT EVIDENCE Screenshots, interviews, reconstructed at audit time.	AUDIT EVIDENCE Role matrix, access reviews, gaps between documented and enforced.	AUDIT EVIDENCE Policy repository, unified decision log, test suite.	AUDIT EVIDENCE Continuous evidence feed, framework-aligned on demand.
BOARD CONVERSATION Reassurance. The real picture isn't on the agenda.	BOARD CONVERSATION Quarterly access reviews. Mostly on time.	BOARD CONVERSATION Metrics. Time-to-revoke, policy coverage.	BOARD CONVERSATION Dashboard with trends. Same cadence as vulnerability posture.
TYPICAL INCIDENT Orphaned service account writes to prod. Found at audit.	TYPICAL INCIDENT Feature flag ships a permission the matrix never anticipated.	TYPICAL INCIDENT Rare. Root cause is policy over-permissiveness, fixable in a PR.	TYPICAL INCIDENT Goal at Stage 4: in-session detection and termination, reported in hours.

Maturity increases left to right. Coverage, ownership, and audit evidence all strengthen at each stage.

Stage 1. Ad-hoc

At Stage 1, authorization is something that happens inside application code and only inside application code. A product engineer has written `if user.role == "admin"` in dozens of services. Another engineer has written a slightly different version of the same check in another service. A third has put the logic in middleware. A fourth has cached the result somewhere and forgotten to invalidate it. Permissions get added when features get added, reviewed by whoever reviews the pull request, and remembered by the people who wrote them until those people leave. Nobody has a full list of who can do what. When a new regulator, a new acquirer, or a new auditor asks for an access review, engineering disappears into the code for a week and comes back with a best guess.

On paper, the CISO owns this. In practice it is owned by whichever engineer last touched the code path. Auditors see screenshots, README files, and the sentence "we'll need to ask the team who built this." Evidence is reconstructed at audit time from artefacts that were not designed to be evidence. Boards hear a reassuring version of the story, because nobody has told them the less reassuring one.

The failure mode at Stage 1 is silent. An orphaned service account, created by an engineer who has since left, runs nightly jobs against the customer database with permissions nobody can explain, because the account was never tied to any HR record and offboarding never reached it. An API token issued two years ago for a one-off integration still has write scopes nobody has reviewed, granting more than the use case ever required. A junior engineer ships a permission check that lets one tenant read another tenant's data, and a customer notices six weeks later. These incidents put CISOs on CNN Live at Stage 1.

What keeps programs there is not negligence. It is ownership. Moving off Stage 1 feels like an engineering refactor, not a security project, and budget and accountability fall between the cracks. Rob Crowe, Principal Engineer at Utility Warehouse, described their pre-Cerbos state bluntly in a [customer story](#). "We realized that our 200+ engineers were doing their own thing, we didn't have a standard way." That is Stage 1, described by someone who lived in it. It is not unusual. Most product-led companies that have grown past thirty engineers have a version of it.

Stage 2. Documented

Stage 2 is the stage most organizations believe they are at. Roles are defined. There is a spreadsheet, an IGA tool, or an access review platform that says what each role is supposed to be able to do. Joiner-mover-leaver flows exist. Quarterly access reviews happen, at least for some systems. From a compliance perspective, the program looks mature.

The gap at Stage 2 is between what is documented and what is actually enforced. The role matrix says one thing. The code does another. Some services check the role matrix at login. Others ignore it and read permissions from a local cache that drifted two releases ago. Some engineers write role checks by hand because the shared library is annoying. A feature flag ships a new permission combination that the role matrix did not anticipate, and nobody notices for six months because enforcement and policy live in different places.

IAM owns admin-time. Engineering still owns what actually runs. Auditors see the role matrix, the access review tickets, and the evidence that the two do not always agree. The findings that land at Stage 2 tend to be effectiveness findings rather than design findings, which on the surface sounds less serious but in practice is more expensive, because effectiveness findings require you to prove remediation in running systems rather than in documents.

Messerschmidt is specific about why this stage fails to meet modern requirements:

"RBAC is not sufficiently able to resolve many modern access use cases... and organizations sitting at Stage 2 are left choosing between increased risk or increased effort."



Phillip Messerschmidt
Deputy Chief of Advisory
kuppingercole
ANALYSTS

Published by  **cerbos**

Stage 2 is where the ratio between compliance paperwork and real risk reduction starts to go the wrong way. More controls, more tickets, more spreadsheets, and the actual authorization decisions still happen in code nobody has a single view of. Olivia Rose, founder of Rose CISO Group and former CISO at Amplitude, Mailchimp, and Just Eat, described the pattern that sits underneath it. "Security teams keep buying new technologies, looking for the silver bullet, almost praying that this will solve their problems." Stage 2 authorization programs that try to buy their way out of the enforcement gap with more tools usually end up with more tools and the same gap.

Board conversations at Stage 2 are mostly about access reviews. The CISO produces a quarterly report on review completion. The numbers look acceptable. Underneath the numbers, the enforcement gap is still there, and it is the thing that will actually cause the incident.

Stage 3. Centralized

Stage 3 is where authorization becomes a layer of its own, separable from any individual application. Policies are written as code, stored in a version-controlled repository, reviewed like any other code, tested like any other code, and deployed like any other code. A policy decision point evaluates requests across services, so the service asks "can this identity do this to this resource right now" and gets an answer that came from a central place.

The decision is no longer just role-based. Attributes that matter show up in the

policy: resource sensitivity, data classification, time of day, tenancy, device posture, geography. The policy is expressive enough to represent the decision the business actually wants to make. The auditor no longer has to ask nine teams how a permission check works, because there is now one place to look.

Ownership usually sits with a platform team or a security engineering function, and the CISO has a view. Auditors see a policy repository with commit history, a unified decision log with identity-level and resource-level traceability, and a test suite that demonstrates the policies enforce what they claim to enforce. Evidence is produced as a by-product of running the system, not reconstructed at audit time. That single shift, from reconstruction to production, is what moves audit prep from a six week project to an afternoon.

Steve High, Staff Engineer at Complex, described the day-to-day difference at the stage-2-to-3 transition better than we could, in Complex's customer story. "It used to be that somebody on the product team goes to change something, and we forgot to change it in 9 of 10 places." The centralized layer means that a permission change is a single edit to a single policy, reviewed, tested, deployed, and evidenced in one motion. The nine places disappear.

Boards at Stage 3 hear metrics rather than stories. Time-to-revoke, policy coverage, the percentage of production traffic flowing through the central decision point. The conversation becomes managerial rather than aspirational. What is not yet covered at Stage 3 is the part of authorization that happens during a session rather than at the start of one, the behavioral signals that should change a decision mid-flight, and the governance of the non-human identities that are now the majority of the estate. Stage 3 is a good place to be. It is not the last stop.

Stage 4. Governed

Stage 4 covers all four of Messerschmidt's timing stages. The policy is defined at admin time. It is enforced at session initialization. It is re-evaluated during the session as context changes, risk signals move, and new information arrives. And the

decisions that are made feed back into policy through post-event analytics, so the policy improves based on evidence rather than on the last incident.

Decisions at Stage 4 are request context driven. A support agent who could access a customer record from an office laptop during working hours cannot necessarily access it from a personal phone at 2am. A service account that is allowed to read from one database schema cannot write to another simply because the credential is the same. An AI agent that is allowed to draft an email is not allowed to send it without a separate check, even if the underlying credential is identical.

Human and non-human identities are governed by the same policy model, which matters because the estate is now mostly non-human. The question for an authorization layer changes shape when agents are in scope. Where once it was "Is this person authorized to run this code", the harder version becomes "Should this code run, even if this agent is authorized for it". Stage 4 is where that harder question becomes a routine part of the authorization decision, not a future roadmap item.

Board reporting at Stage 4 looks like board reporting for vulnerability management. Exposure duration, time-to-revoke, policy coverage across human and non-human identities, post-event trend analysis. The CISO is no longer presenting a narrative about authorization. They are presenting a dashboard. The conversation with the audit committee becomes similar to the conversation with the audit committee about patching. Numbers with trends, compared against agreed targets, with named owners. Regulators respond to that kind of evidence. Boards respond to that kind of evidence. Attackers notice.

At Stage 4 the policy model also carries delegation chain awareness, so a decision is made not only against the requesting identity but against the full chain of identities and intents that produced the request, including the human principal who originally delegated.

Stage 4 is not a destination many organizations have fully reached. It is the direction the analyst community, the regulatory community, and the insurance community

are all pointing in, and it is the direction the rest of this guide assumes you are moving towards. The next three chapters are about how to get closer to it.



Chapter 3

Self-assessment. Where are you today?



Before you can plan a move, you need to know honestly where you are standing. This chapter is a short self-assessment, fifteen questions across five sections. **Answer them as the program actually runs today, not as the documentation claims it runs.** The output is a stage placement for your authorization program as it exists in production right now.

Most CISOs find the honest version of this assessment places them a stage below where the compliance documentation would place them. That is not a failure. It is the gap this guide exists to help you close, and seeing it accurately is the first useful step.



Authorization self-assessment scorecard

Fifteen questions across five sections. Answer each one honestly, then count your confident yeses and find your authorization maturity stage at the bottom.

A Coverage and ownership

Authorization is a structural concern, and structures need owners. These three questions are about whether anyone in your organization can draw a picture of the program from end to end.

- ☐ Can one person, within an hour, produce a complete list of every service in production that enforces authorization, and describe how each one does so?
- ☐ Is there a single team accountable for the authorization layer across the company, with a named leader who can be held to outcomes?
- ☐ Does your CISO receive a regular report on authorization posture in the same way they receive reports on vulnerability posture?

B Policy and evidence

Policies that exist only in code, or in spreadsheets that drift, cannot be audited. These three questions are about whether your policies are artefacts you can point to, test, and prove changes to.

- ☐ Are authorization policies stored in a version-controlled repository with code review, test coverage, and an audit history?
- ☐ When a policy changes, is there a decision log that shows what was different about the decisions made before and after the change?
- ☐ Can you produce, on demand, a report showing every access decision made by a specific identity over the last 90 days?

C Runtime behaviour

The difference between Stage 2, Stage 3, and Stage 4 shows up most clearly during a session. These questions are about whether your authorization layer reacts to what is actually happening, or only to what happened at login.

- ☐ Are authorization decisions re-evaluated during long-running sessions, or only at login?
- ☐ Do decisions incorporate context beyond role, such as resource sensitivity, time of day, device state, or geography?
- ☐ If a user's risk signal changes mid-session, does authorization respond without a full logout or session reset?

D Non-human identities

The fastest-growing category of identity in your estate has no manager, completes no access reviews, and has no HR record. These questions are about whether it is governed with the same care.

- ☐ Do service accounts, workloads, and AI agents go through the same policy model as human users?
- ☐ Can you list every AI agent or autonomous workload in production today, what it is allowed to do, and who owns it?
- ☐ When a non-human identity's scope changes, is there a review step, and is that step documented?

E Response and governance

Finally, three questions about what happens when authorization needs to move quickly, and about whether the program is visible to the people who will be asked about it.

- ☐ Can you revoke an identity's access to every system in under five minutes, and prove the revocation took effect?
- ☐ Is authorization coverage one of the metrics your board sees at least quarterly?
- ☐ Do post-event analytics feed back into policy revision on a defined cadence, rather than only after an incident?

Scoring

Answer "yes, confidently" to each question. Soft yeses do not count. Count your confident yeses and find your authorization maturity stage below.



Most programs we see at serious B2B SaaS companies sit at Stage 2, with one or two answers from Stage 3, typically in sections B and E. If that is you, you are not behind. You are the median. The question worth asking is not whether you are at the destination but whether you are moving, in which direction, and at what pace. The next two chapters are about answering that question.

Chapter 4

Risks and regulatory exposure at each stage

Regulatory exposure by stage

Severity gradient based on published audit findings and enforcement data.

	STAGE 1 Ad-hoc	STAGE 2 Documented	STAGE 3 Centralized	STAGE 4 Governed
SOC 2	Critical	High	Medium	Low
ISO 27001	Critical	High	Medium	Low
HIPAA	Critical	Critical	Medium	Low
PCI DSS 4.0	Critical	High	Medium	Low
GDPR	Critical	High	Medium	Low
NIS2	Critical	Critical	High	Low
DORA	Critical	Critical	High	Low
SEC disclosure	Critical	Critical	High	Medium
EU AI Act	Critical	High	Medium	Low

Published by  cerbos

Each cell is a judgement, graded against published audit findings, enforcement actions, and the regulation text. [Full sources](#) at the end of this chapter.

Each stage in this model carries a distinct risk profile. Auditors ask different questions at each one. Regulators look for different artefacts. Boards respond to different metrics. Attackers find different surfaces. Mapping that exposure honestly is more useful than describing it in the abstract, because the exposure is what the CISO actually has to answer for, in a room full of people who will not accept an aspirational answer.

The newest of these regulators, the EU AI Act, maps onto the model almost stage by stage. Article 9 risk management is achievable in principle at any stage but only credible from Stage 2 onwards. Article 10 data governance assumes you can tell what data an authorized identity actually reached, a Stage 3 capability in practice. Article 12 record-keeping requires the end-to-end audit trail that only Stage 4 produces continuously, and that trail has to survive delegation.

Exposure at Stage 1

At Stage 1 the failure modes are silent until the day they are not. An orphaned service account from a long-departed engineer keeps writing to production because nobody knows who owned it and the offboarding checklist never reached it. An API token issued years ago for a one-off integration carries write scopes nobody has reviewed since, granting more than its current job needs. An engineer ships a permission check that crosses tenant boundaries in a mistake that a code review does not catch. None of it shows up in the board pack. All of it shows up in the headlines if the wrong person finds it first.

This is the stage regulators punish hardest. NIS2 requires management bodies to approve and oversee cybersecurity risk management measures, and a best-effort engineering reconstruction is not an acceptable form of oversight. In the UK, the Information Commissioner's Office fined British Airways £20 million, reduced from an initial £183 million, in a 2020 enforcement action. The penalty cited a chain of failures including weak access controls, generic admin accounts without MFA, and insufficient measures that allowed attackers to move laterally after an initial Citrix compromise. Authorization was one strand of the finding; the broader penalty was for failing to demonstrate effective technical and organizational measures. The same pattern sits underneath many of the SEC enforcement actions that have followed the 2023 disclosure rules.

The question the audit committee asks at Stage 1 is the one that is hardest to answer. "Can you prove to me that our former contractor does not still have access to customer data?" At Stage 1 the honest answer is "no, we will have to go and look."

Exposure at Stage 2

At Stage 2 the failure modes are documented but not enforced. The role matrix says one thing. The code does another. The access review tickets get closed. The permissions that slipped through do not show up until a SOC 2 evidence pull six months later.

Giao Nguyen, IAM Advisor at 1Kosmos, described the same dynamic in our recent [discussion](#):

"The data is fragmented across different teams. CISOs aren't necessarily privy to all the information. So during an audit or incident, people scramble. That's when it becomes a fire drill."



Giao Nguyen
IAM Advisor
 1KOSMOS

Published by  **cerbos**

The regulatory picture at Stage 2 is more demanding than it looks. DORA's operational resilience testing expectations reward organizations that can demonstrate enforcement continuously, and penalize organizations that can only demonstrate design. ISO 27001's Annex A controls around access rights require the same, through evidence that effectiveness matches documentation. SOC 2 Type 2 audits focus on the operational effectiveness of controls over time, which is precisely where Stage 2 programs tend to produce findings. The pattern is consistent. Stage 2 fails effectiveness, not design, and regulators have moved their expectations towards effectiveness across every major framework in the last three years.

The board question at Stage 2 becomes more pointed than at Stage 1. "Does the enforcement match the policy?" The CISO at Stage 2 can usually answer, but the answer includes caveats, and the caveats are what the audit committee writes down.

Exposure at Stage 3

At Stage 3 the failure modes narrow significantly. Centralized authorization with policy as code closes most of what Stages 1 and 2 leave open.

The remaining exposure consolidates in three places. Non-human identities that are not yet governed by the same policy model, which in 2026 is a larger exposure than

most CISOs would have described it a year ago. Session-level risks that are not re-evaluated after login, which matters more in a world of long-lived sessions and AI agents than it did in a world of short interactive browser sessions. And decisions made without enough context, either because the context is not being collected or because the policy does not know how to use it.

Reiner Mertens recently walked through how this happens. A customer service agent named Alice flows through an API gateway, a case service, a customer data service, and a database. Alice is entitled to view records assigned to her team. The service account in the chain is entitled to read every record. The result, in his words, is that "the service's permissions replaced the user's permissions," and the agent returns every record matching the case. A Stage 3 program with centralized policy but no per-hop authorization cannot demonstrate, to a regulator, that Alice's context survived the chain. That is the gap the EU AI Act's Article 12 turns into a compliance question.

Audits at Stage 3 are a different conversation. SOC 2 evidence maps cleanly to artefacts the program produces. ISO 27001 Annex A controls produce themselves as a by-product of the policy repository and the decision log. HIPAA audits look for the same access control evidence and Stage 3 programs pass the bar. Chuck Hardy, Head of Engineering at Salesroom, put the human side of the shift plainly in their customer story. "Deploying Cerbos has allowed our engineers to spend their time on what really matters for Salesroom's success. And I sleep better at night." Sleeping better at night is a Stage 3 outcome.

The board question at Stage 3 shifts forward. "What is our coverage for AI agents and service accounts, and how do we know?"

Exposure at Stage 4

At Stage 4 the remaining risk is operational rather than structural. Policies still need to be written correctly. Decisions still need to be monitored. Regressions still need to be caught by the test suite. None of that is trivial, but it is the kind of work the

program is designed to do, rather than the kind of work the program cannot do.

The regulatory alignment at Stage 4 is clean. NIS2, DORA, SEC disclosure, ISO 27001, SOC 2, HIPAA, PCI DSS 4.0, and GDPR Article 32 all map against the same underlying evidence. The decision log that the program produces continuously is the evidence for all of them, with different lenses. An audit is a query against that log rather than a project that begins with a kick-off meeting.

The board question at Stage 4 is a trend question. "How does our exposure duration compare to this time last quarter?" That is the question a CISO at Stage 4 can answer from a single slide.

"Regulatory exposure by stage" visual sources:

1. SOC 2: CC6 and CC7 account for 68% of audit exceptions in qualified reports.
2. ISO 27001: Privilege creep and delayed revocation are the top causes of major nonconformities.
3. HIPAA: OCR settled 22 enforcement actions totaling \$9.4M+ in 2024.
4. PCI DSS 4.0: Requirement 7 mandates 6-month access reviews; Requirement 10 mandates automated SIEM logging with 1-year retention.
5. GDPR: Article 32 fines totaled €1.2B in 2025.
6. NIS2: Article 20 establishes personal management liability; Germany's BSI issued 47 formal notices in Q4 2025.
7. DORA: Article 9(4)(c) makes least-privilege a legal obligation.
8. SEC: Enforcement includes R.R. Donnelley (\$2.1M, Jul 2024) and Flagstar's misleading Form 8-K (Dec 2024); the Cyber and Emerging Technologies Unit formed Feb 2025.
9. EU AI Act: Articles 9, 10, 12, and 13 apply to high-risk AI systems from 2 December 2027 (standalone Annex III systems) and 2 August 2028 (AI embedded in Annex I regulated products), per the May 2026 omnibus agreement. Article 99 sets fines up to €35M or 7% of

global turnover for breaches of the Article 5 prohibited-practices ban (already in force), and €15M or 3% for most other obligations. Regulation (EU) 2024/1689.

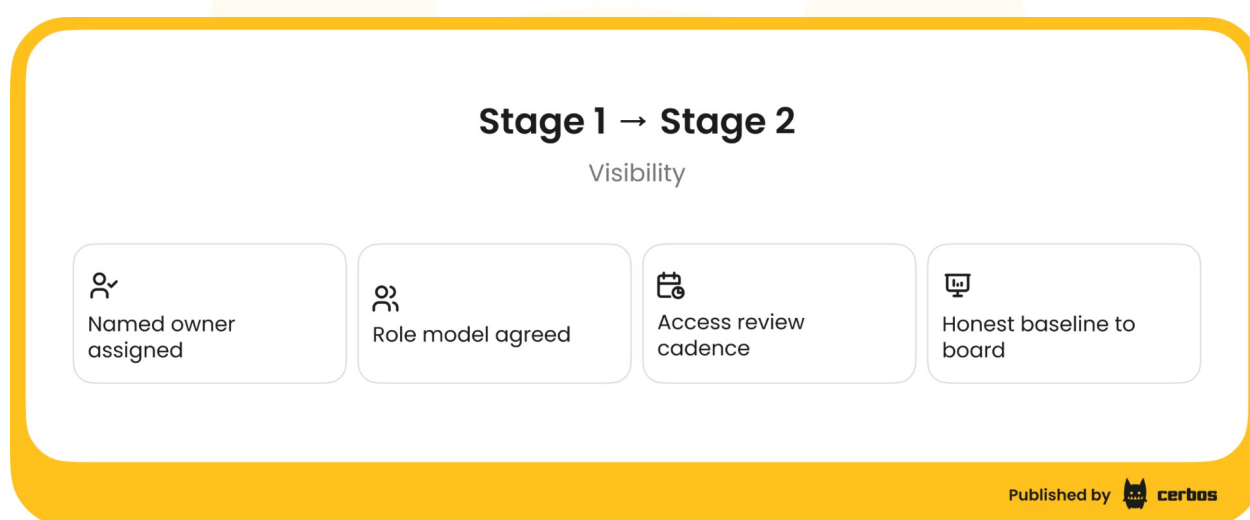
Chapter 5

Moving up the model



Transitions in an authorization program take months, not weeks. They are not pure technical projects, and the programs that treat them as pure technical projects usually stall around month four. Each move up the model is a change in team, process, evidence, and what the board hears. This chapter is the honest version of what each transition demands, and where we have seen programs succeed and get stuck.

Stage 1 to Stage 2



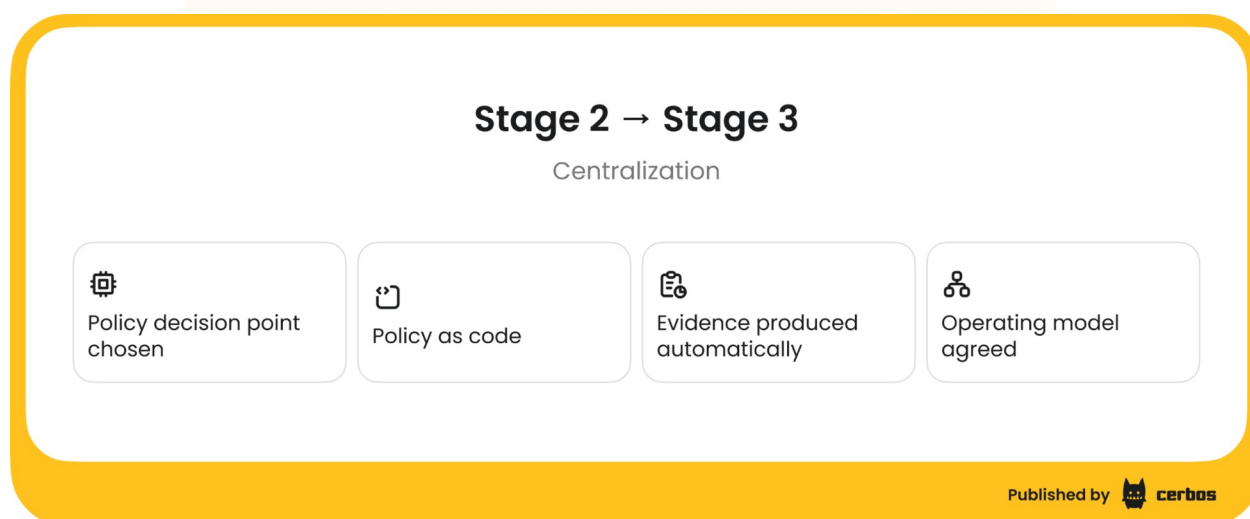
The hardest part of the first move is visibility, not enforcement. You cannot document a role model you do not have an accurate picture of, and the act of producing that accurate picture is usually painful. Somebody has to audit what authorization decisions are actually being made in the code base. The audit always surfaces things nobody remembers writing, scopes nobody remembers granting, and services nobody remembers setting up.

What changes during this transition is ownership, documentation, and review cadence. A named owner is assigned to the authorization program, ideally a person rather than a committee. A role model is agreed that engineering will follow for new work, even if existing code does not yet conform. An access review process is put in place, using whatever tooling the organization already owns, on a cadence that is actually run rather than aspirational. An IGA tool is introduced if one is not already present. None of this, critically, requires a change to the underlying architecture.

Stage 2 can coexist with authorization logic living in code, as long as there is now a documented source of truth to compare the code against.

The board conversation at this transition is the most uncomfortable of the three moves. "We are establishing visibility. The work up to this point has been invisible to us. It will take one to two quarters to produce a clean baseline, and the first version of that baseline will include findings we did not previously know about." That is the honest version, and boards respond to honesty at this stage better than they respond to optimism.

Stage 2 to Stage 3



This is the transition most serious organizations are in the middle of right now, and it is the one with the most failure modes. It is also the transition where the business case is clearest, because the difference between Stage 2 and Stage 3 is the difference between audit-prep-as-a-project and audit-evidence-as-a-by-product.

At Stage 3, authorization becomes a distinct layer with its own repository, pipeline, and test suite. Applications call a policy decision point rather than evaluate policy locally. Engineering teams stop writing permission checks by hand and start writing them as policy. Policies are written by security, platform, or a federated model that includes both, depending on the size of the organization. Evidence is produced automatically rather than assembled manually, which changes the economics of

compliance substantially.

The failure mode we see most often is treating this as a tooling decision. Picking a policy decision point product and assuming the transition is mostly done. Jack Klecha, Vice President of Enterprise Information Security at Cisco, put the general fallacy plainly:

"One of the bigger fallacies of introducing a new tool is that you write a check, and the problem goes away."



Jack Klecha
VP of Enterprise Information Security


Published by  **cerbos**

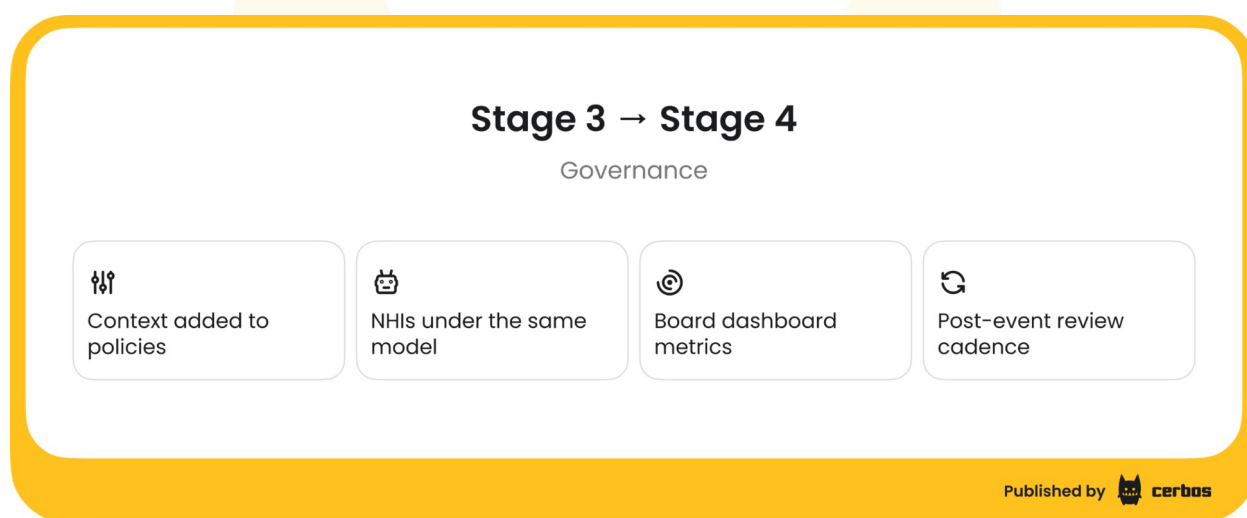
In practice, the tool is the easy part. The team model, the review process, the training, and the hand off from engineering to platform is where programs stall. The engineers who wrote the original permission checks have opinions about how the new system should work. The platform team has opinions about who maintains the policies once they are written. The security team has opinions about who approves policy changes. Those opinions have to be resolved into an operating model, and the organizations that skip that conversation end up with a policy decision point sitting in production that nobody is actually writing policies for.

Je Sum Yip, Chief Engineer at Human Managed, a Cerbos customer, described the post-transition state the way it should feel when the operating model is right. "Having to modify authorization is a five minute job now. Having to troubleshoot authorization is a five minute job." That is the Stage 3 reality a year after the transition, not the week after. Organizations that get the operating model right hit that five minute number. organizations that do not, do not.

The board conversation at this transition is the easiest. "We are centralizing the authorization layer. During this transition our evidence picture will temporarily look

worse before it looks better, because we are now able to see things we could not see before. Here is the timeline, here is the metric we will report against, here is the stage we expect to be at in two quarters." Boards respond well to this conversation when the metric is credible and the timeline is not theatrical.

Stage 3 to Stage 4



Stage 3 to Stage 4 is not a rewrite. It is an extension. Context awareness gets added to policies that already exist. Continuous evaluation during sessions gets added to decisions that already flow through the central layer. Non-human identities are brought under the same policy model that already covers humans. Post-event analytics get connected to policy revision on a cadence that is agreed in advance.

The part that changes most is board reporting. At Stage 4, the CISO reports on exposure duration, time-to-revoke, and policy coverage in the same motion as they report on patch velocity and vulnerability backlog. That shift requires agreed definitions, agreed measurements, and a reporting cadence that is not only quarterly. It also requires the IAM, platform, and security engineering teams to agree on what the numbers mean, which is usually harder than agreeing to produce them. Phil Venables framed the discipline plainly in his Good CISO / Bad CISO essay. "Good CISOs communicate in the language of the business: risk, capital, and opportunity. They quantify risk to provide evidence, not anecdotes." Stage 4 is the state in which the authorization program produces that evidence as a matter of course.

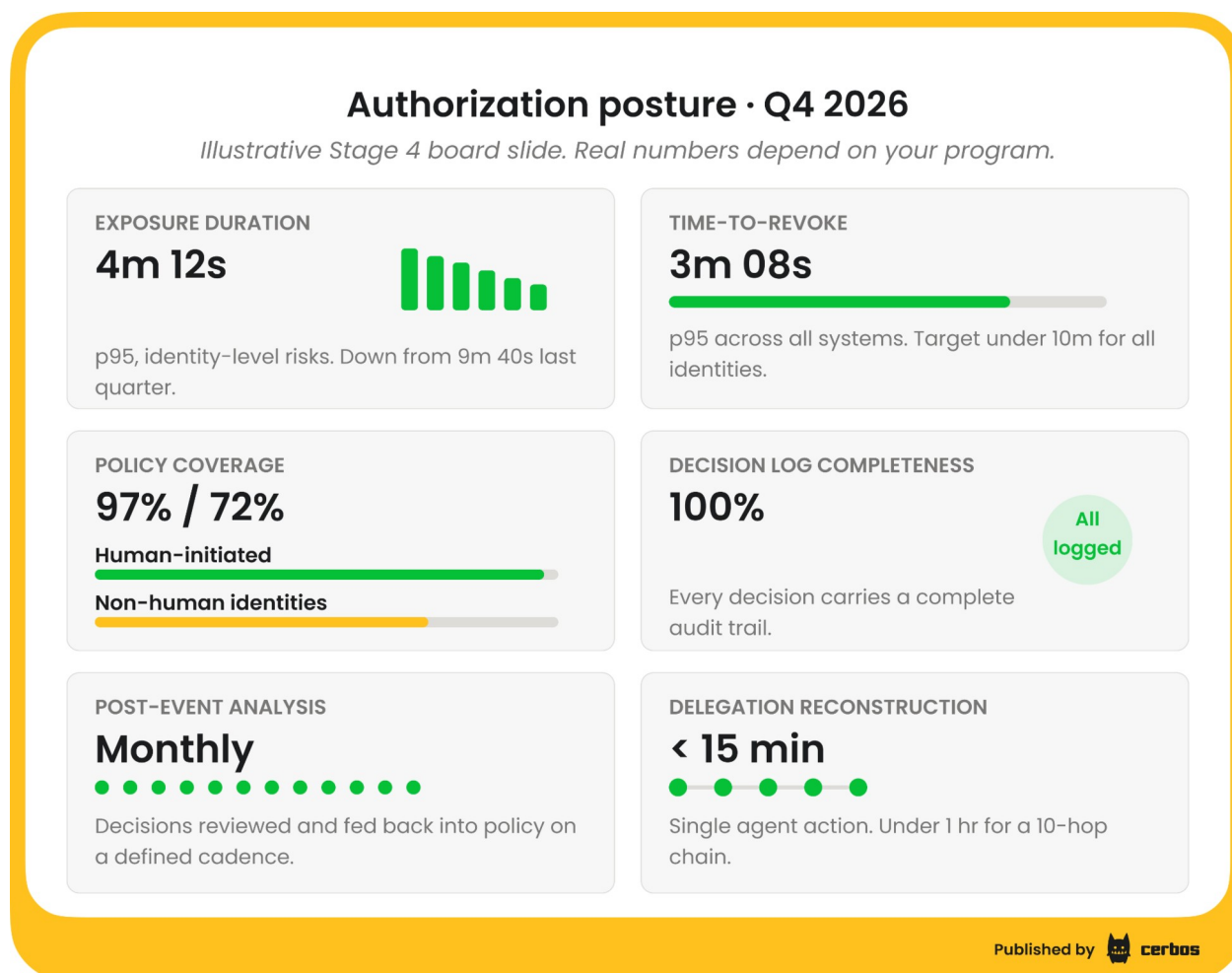
The hardest technical part of this transition is governance of AI agents. Three layers of agent governance need to come together for Stage 4 to hold. The first is deterministic governance: what the agent can touch at all. Most Stage 3 programs handle this by extending the existing policy model to cover agent identities. The second is behavioral analysis: how the agent usually behaves and how to detect when it does not. Fewer Stage 3 programs have this in production. The third is real time intent governance: whether the agent should do a specific thing now given context and risk, even when its credential allows it. Very few programs have this operationalized. Getting to Stage 4 means committing to all three, not to the first one only.

The board conversation at this transition is the most mature of the three. "Authorization posture now appears on the same dashboard as vulnerability posture and identity posture. Here is the picture this quarter, here is the trend, here is the control we are pulling next." At this point, the CISO is no longer explaining what authorization is. They are managing it.

Chapter 6

What good looks like





Stage 4 is not an abstract state. It produces a specific set of outcomes that boards recognize, that regulators reward, and that incident responders notice during a real event. The targets below are not industry standards. They are the numbers we see working in mature authorization programs, with Kara Sprague's [Exposure Velocity Model](#) as an underlying frame. Treat them as starting points and tune them to the risk you are willing to carry.

Outcome 1: Exposure duration

Exposure duration is the time between a risk signal being raised, whether from an external report, an internal detection, or a change in a user's context, and the corresponding access being revoked or scoped down. This is the authorization version of Sprague's velocity metric. "Delay is the risk," as she puts it, and at Stage 4 you have a number for the delay. Target exposure duration is measured in minutes for identity-level risks and hours for policy-level ones. What that number is matters

less at first than whether you have it, whether it is trending in the right direction, and whether the board sees it alongside other velocity metrics rather than on a slide of its own.

Outcome 2: Time-to-revoke

Time-to-revoke is the time between a revocation request and provable loss of access across every system that identity could previously reach. Provable is the important word. Attestation from a team is not evidence. A decision log that shows the subsequent access attempts being denied is. Target time-to-revoke is under ten minutes across all identities, with the recognition that non-human revocation often requires coordinated rollover rather than hard cutoff. Organizations that hit those numbers consistently are organizations that can tell a regulator, in the room, that a departed insider does not have access any more, and can point to the log entry that proves it.

Outcome 3: Policy coverage

Policy coverage is the percentage of services, workloads, and agents whose authorization decisions flow through the central decision point. Target above 95% for human-initiated traffic, tracked as a number the program actually drives against rather than a number that sits in a slide. Non-human coverage should be tracked as a separate number, because it lags and because the 2026 growth in non-human identities means the number moves in both directions depending on what the engineering org has built in the last sprint.

Outcome 4: Decision log completeness

Decision log completeness is the percentage of access decisions for which you can produce a complete audit trail, including the policy version, the identity, the resource, the context at decision time, and the outcome. Target is 100% for production. Anything less is an evidence gap, and evidence gaps compound.

Outcome 5: Post-event analysis cadence

Post-event analysis cadence is how often the decisions being made are reviewed and fed back into the policies that produce them. Target is monthly. At Stage 4 this is a routine operational practice, not an incident-triggered emergency. The programs that get to Stage 4 and stay there are the programs that treat post-event review as a normal part of the authorization calendar, in the same way patch review is a normal part of the vulnerability management calendar.

Outcome 6: Delegation reconstruction time

For any agent action in the last 30 days, the program can reconstruct the full chain, which human delegated, to which agent under which policy, with what context, against which resource, with what outcome, within minutes rather than days. The decision log is the source of truth. The reconstruction is a query, not a project. Target is under fifteen minutes for any single action and under one hour for a chain of up to ten hops. This is the working definition of audit-readiness for agents, and it is the metric the EU AI Act, the SEC cyber rules, and incoming sector-specific regulators are all converging on.

Those six outcomes then map against the regulatory frameworks that your audit committee actually cares about. The decision log that the program produces continuously is the underlying evidence for each. Different lenses, same artefact.

Framework	What Stage 4  gives you
SOC 2	Continuous evidence for the CC6.1, CC6.2, and CC6.3 access control criteria
ISO 27001	Annex A.5 and A.8 controls produced automatically rather than assembled
HIPAA	§164.312(a) access control technical safeguards proven continuously
PCI DSS 4.0	Requirement 7 access restriction and Requirement 10 logging evidence on demand
GDPR	Article 32 technical and organizational measures, with proof rather than assurance
NIS2	Article 21 risk management measures evidenced in real time
DORA	Article 9 ICT risk management requirements with audit-ready logs
SEC 17 CFR 229.106	Materiality decisions supported by access evidence rather than narrative
EU AI Act	Articles 9, 10, 12, and 13 evidenced continuously, with record-keeping that survives delegation

Published by  **cerbos**

At Stage 4, the same model applies to AI agents as to human users. This matters because the estate is now mostly non-human, and because the regulatory and reputational exposure from an agent with excessive permissions is equal to the exposure from an employee with excessive permissions, and in some respects larger.

As [GitGuardian's recap](#) of the 2026 Gartner IAM Summit put it, the consensus message from the practitioner community that week was that AI does not work at scale without identity and authorization controls underneath it. Stage 4 is the state where that is no longer a future problem. It is a set of policies and a set of metrics, operating on the same cadence as the human identity program.

Chapter 7

Authorization for AI agents



The last chapter ended on a claim that at Stage 4 the same model covers agents and humans alike. This chapter is about what that actually takes. Most of this guide applies to authorization whatever the principal asking the question. The agent case is the part that does not, because agents strain every part of the model at once.

AI agents combine three properties no prior identity type carried together. They act non-deterministically, in the sense that the same task produces a different sequence of API calls every time. They act under delegated authority, often nested several levels deep. And they act at machine speed, completing in milliseconds what a person would have taken minutes to consider. Authorization layers built for human users handle one of those properties at best. Stage 4, as defined in Chapter 2, has to handle all three.

The number of agents in your estate is also not what it looks like in the all-hands deck, and verifying it is part of the work of the first thirty days. The CyberArk landscape report cited earlier put machine identities at 82 to 1 over humans, and agents are pushing that number up, not down.

Why human-shaped authorization breaks for agents

The most useful frame on this comes from Dr. Phillip Messerschmidt at KuppingerCole, whose four timing stages anchor Chapter 2. He has been direct about where agents sit on the difficulty curve. "Agentic AI is the most unpredictable of the non-human identity types," he said. Authorization for a service account is hard because there is no manager and no HR record. Authorization for an agent is harder because, on top of having neither, the agent will make decisions you did not anticipate, in sequences you did not plan for, on data you did not classify, using tools you did not pre-authorize.

The point is not that agents are dangerous. It is that the authorization layer now needs to know three things about every request where it used to need one.

The authorization layer now needs to know 3 things



Principal

Agent, human who delegated to it, and often more once sub-agents are involved



Purpose

Bounded scope the agent was set up for (not the open-ended user prompt)



Behaviour

Sequence of calls and data accesses at runtime, judged against policy

Published by  **cerbos**

The first is the principal, which for an agent is at least two parties, the agent itself and the human who delegated to it, and often more once sub-agents are involved. The second is the purpose, the bounded scope the agent was set up for, not the open-ended user prompt. The third is the behavior, the actual sequence of calls and data accesses the agent makes at runtime, judged against policy as it happens.

An authorization layer that sees only one of those three, almost always the agent itself, is working with two thirds of the picture missing.

Per-hop authorization is the architectural floor

The [Alice example in Chapter 4](#) is the practical version of this. A service account in the chain has broader scope than the user it acts for, the chain collapses her context into the service's, and the agent returns every record matching the case rather than every record matching her team.

There is a standards-based answer that does not require new infrastructure. Token exchange, an established [OAuth 2.0 standard](#), lets each service in the chain pass along both its own identity and the delegating user's, so the next service decides against the full chain rather than the last identity it saw. The pattern has a name, per-hop authorization.

Every service in the agent's path decides against the whole chain, and every decision is logged with the identity, the policy, and the outcome, so the chain can be reconstructed end to end afterwards. That is what regulators are starting to ask for, and what most programs cannot yet produce.

The gap is not a tooling gap. Reiner Mertens made the case at EIC 2026 that the standards are mature and the tools exist. What is missing is the organizational positioning, whether IAM is actually in the room when APIs are designed.

Audit trail collapse is the compliance risk

The same point has been made from the audit side. Building on Kim Cameron's 2005 Laws of Identity, the conversation in 2026 has been about extending those principles to agents. The one that matters most for CISOs is the principle of justifiable action. Every agent action must be reconstructable end to end, from a record that names the human principal, the agent and model version, the policy that authorized the call, and the delegation scope.

Most production logs today capture four fields, a timestamp, an actor, an action, and a target. That does not meet the bar, and a four-field log with a sub-agent chain does not even tell you who delegated.

The reason this matters now is that the EU AI Act deadlines, even pushed to 2027 and 2028, leave less runway than they appear. Article 12 requires record-keeping that lets an operator reconstruct what the system did and with what inputs. Article 13 requires transparency to deployers about how the system works and its limits. The standard your program has to meet, whichever regulator is asking, is that any agent action across a rolling 30-day window can be reconstructed end to end, with the original human consent and every delegation hop intact. That is the working definition of audit-readiness for agents.

What CISOs should be asking vendors right now

The vendor conversation around agent authorization in 2026 is heavy on capability claims and light on evidence. The most useful filter we have seen comes from Jonathan Care at KuppingerCole. The eight questions below are paraphrased from his framing. Each has a yes or no answer, and each is verifiable in a proof of concept.



What to be asking vendors around agent authorization

- 1 Does the platform issue a distinct identity per agent instance, not per agent class, with the ability to issue, rotate, and revoke that identity independently of any other agent?
- 2 Can it deliver scoped credentials in under an hour, valid only for a defined set of tool calls, replacing any need for long-lived API keys?
- 3 Can the audit trail reconstruct, for any action in the last thirty days, the prompt, the model version, the tools invoked, and the authorising human, in a single query?
- 4 Is policy enforced at the orchestration layer, independent of the agent's own code, so a compromised or jailbroken agent cannot bypass it?
- 5 When an employee leaves, are the agents they delegated to shut down automatically within minutes, without manual intervention?
- 6 When the control plane is unreachable, does the platform fail closed by default?
- 7 For EU AI Act Articles 9, 10, 12, and 13, can the vendor show the specific clause its product satisfies, with evidence, not just the clause it supports?
- 8 Is the delegation chain visible in the audit log, with the human consent that originated it, surviving every hop?

A vendor that can answer yes to all eight, with artefacts, is operating at the Stage 4 standard from Chapter 2. A vendor that cannot is selling capability rather than control.

What changes in your maturity model

Stage 4 for agents is the same Stage 4 from Chapter 2, applied. The policy model covers human and non-human identities under one engine. Decisions are evaluated continuously, not only at session start. Decisions carry the delegation chain, not only the requesting identity. Decision logs are produced continuously and are queryable across a window measured in days, not quarters.

The principle does not change. The bar moves up, because the regulator's expectations and the attacker's capabilities have both moved up.

Programs that did the work to reach Stage 3 for human identities have done most of the architectural work to reach Stage 4 for agents. What remains, in order, is identity registration per instance, scoped short-lived credentials, per-hop authorization, and an audit record that survives delegation. The rest is policy.

None of this changes the plan in the next chapter. It raises the stakes on doing it.

Chapter 8

A 30, 60, and 90 day plan



First 90 days

From Stage 2 today to visible momentum on Stage 3

DAYS 1-30 Visibility

- ① Name an owner, a person not a team
- ② One-page honest stage map of production
- ③ Top 5 sensitive-data services documented
- ④ Executive briefing, unsoftened
- ⑤ Inventory every AI agent and autonomous workload

DAYS 31-60 Direction

- ① Choose a policy decision point approach
- ② Choose a policy language you can maintain
- ③ Pilot with one of the five services
- ④ Align with IAM team on admin-time and runtime
- ⑤ Agree the agent identity model and pilot one agent-mediated path

DAYS 61-90 Commitment

- ① Pilot rolled to two more services
- ② First board authorization-posture slide
- ③ Stage 2-to-3 roadmap with named end date
- ④ Metric on the executive dashboard
- ⑤ Track agent identity coverage separately from human coverage

Published by  cerbos

The chapters above describe the shape of the whole model. This one is narrower. If you are at Stage 2 today, which most CISOs reading this guide will be, this is a 90-day view of the first visible part of the transition to Stage 3. Ninety days is not enough to finish the transition. It is enough to establish visibility, pick the architectural direction, and put the first credible metric in front of the executive team. The rest of the work follows if the first part is done with intent.

The first thirty days are about establishing visibility

The first action is to name an owner for the authorization program. Not a team, a person, someone who will be asked about it in twelve months and answer without deflecting.

The second action is to produce a one-page honest assessment of where every production service sits on this maturity model. Not a policy document, an honest map. Do not stop the exercise at "it varies." Vary against what?

The third action is to pick the five services handling the most sensitive data in your environment and document, for each, what actually enforces authorization, who owns it, and what evidence of that enforcement exists today.

The fourth action is to brief the executive team on the current stage, without softening it. That briefing is the thing that unlocks budget for the next sixty days. Soften it and you will spend the next sixty days without budget.

A fifth action belongs alongside the first four if your organization has any agents in production today, and the honest answer to that is almost always yes. Produce a complete inventory of every AI agent and autonomous workload running in production, with a named human owner, the credentials it holds, the systems it can reach, and the data classification of those systems. Most programs find the inventory cannot be assembled from any single source of truth. That fact, on a slide for the executive team, unlocks budget for the next sixty days more reliably than anything else in this plan.

Days thirty-one to sixty are about picking the layer

The main decision in this window is architectural. You are choosing a policy decision point approach, whether open source, commercial, or internally built, and you are doing so knowing it stays with you for years.

A second decision follows from the first, which is the policy language. A YAML-plus-expression-language approach like Cerbos is more maintainable than Rego for most teams, but the right answer depends on the shape of your engineering organization, the frameworks you want to align with, and whether you are committing to AuthZEN as the standard.

Alongside the architectural decision, pilot the new layer with one of the five services from month one. Measure latency, evidence quality, and developer adoption as a trio rather than in isolation. The pilot will tell you more about the operating model than about the technology. That is useful information to get early. In parallel, align with the IAM team on how admin-time policy and runtime policy will meet cleanly.

That conversation is the one most commonly skipped and most commonly regretted.

In parallel with the architectural decision, agree the agent identity model the program will commit to. One identity per agent instance rather than per agent class. Scoped credentials with a defined lifetime measured in hours, not days. Delegation chain captured in the token, not in tribal knowledge. Decision log that records the human principal as well as the agent. The pilot service should include at least one agent-mediated code path, so the operating model is tested against the harder case from the start rather than against the easier one only.

Days sixty-one to ninety are about proving the approach and committing to the program

Roll the pilot to two more services. Confirm that the policy repository, the test suite, and the decision log are producing the artefacts you need them to produce, and that the evidence they produce is legible to the auditors you care about.

Produce the first board-level authorization posture slide, with real numbers for time-to-revoke, policy coverage, and exposure duration, even if the numbers are ugly. The board slide should include agent identity coverage as a number separate from human identity coverage, with the explicit acknowledgement that the agent number will lag and will move in both directions as engineering ships and retires agents. Ugly numbers you can move are more valuable than clean narratives you cannot. Commit to a Stage 2-to-3 roadmap with a named end date, budget, and a metric on the executive dashboard.

Nobody gets from Stage 2 to Stage 3 in ninety days. Most get the first 15% of the way, and that is the part that matters. The rest is a two-to-four quarter program that runs on the scaffolding the first ninety days put in place.

The organizations that skip the scaffolding spend twelve months on an implementation project and then discover they have a decision point but no program.

The organizations that invest in the scaffolding end up with a program the CISO can stand behind in an audit committee meeting, which is the point of the exercise.

That is the work. The rest of this is how we can help.

Close the gap with Cerbos

Wherever the self-assessment in Chapter 3 placed you, the next move points the same way, out of code and into a layer you can govern. Cerbos is built for that move, through to the Stage 4 capabilities this guide points toward, agents, delegation, and continuous decisions included.

Cerbos is an externalized authorization management platform. You authorize every identity and govern every action from one place, with fine-grained, contextual, and continuous decisions and a full audit trail behind every one, across your applications, gateways, workloads, and AI agents.

Policies are written as code, reviewed and tested like any other code, and distributed across your services through a single interface, so your audit evidence is produced continuously rather than reconstructed at audit time.

Human and non-human identities run through the same policy model, so the fastest-growing part of your estate sits inside the program, not outside it.

Cerbos has been part of the OpenID AuthZEN working group from the start and aligns with the now-ratified standard, adopting it is not a lock-in decision.

If that sounds like the conversation your program needs to have in the next two quarters, we would like to have it with you.

Talk to a Cerbos solutions architect about where your authorization program sits today and how to close the gap.

[Book a call.](#)

About this guide

This guide was produced by Cerbos based on conversations with security leaders across regulated industries including fintech, healthcare, and government, as well as B2B SaaS, and on the published work of Phillip Messerschmidt, Reiner Mertens, and Jonathan Care at KuppingerCole, of Kara Sprague at HackerOne, on peer contributions to the Cloud Security Alliance CISO Mythos draft, and on the recaps of the leading IAM and security analyst events.

Lead Author:

Alex Olivier

Contributors:

Emre Baran

Anna Paykina

 **Cerbos** Authorization management platform

Authorize every identity. Govern every action.

Enforce fine-grained, contextual, continuous authorization across applications, gateways, workloads, and AI agents.

[Learn more → cerbos.dev](https://cerbos.dev)

